SOUTENANCE NIS2 · HYDRORÉGIE

ANNEXES

1. Grille de qualification
2. Cotation des 10 domaines de l'article 21
3. Plan d'actions daté et responsabilisé
4. Découpage en 9 zones réseau
5. Matrice de flux
6. Chronologie de crise détaillée
7. Délais réglementaires

Directive (UE) 2022/2555 — documents de référence

ANNEXE 1 · BLOC 1

Grille de qualification

Le statut se déduit du croisement entre le secteur (annexes I et II) et la taille au sens de la recommandation 2003/361/CE.

SITUATION	STATUT NIS2	FONDEMENT
Annexe I + grande entreprise	**ENTITÉ ESSENTIELLE**	**art. 3(1)(a)**
Annexe I + moyenne entreprise	Entité importante	art. 3(2)
Annexe II + grande entreprise	Entité importante	art. 3(2)
Annexe II + moyenne entreprise	Entité importante	art. 3(2)
Petite ou micro entreprise	Hors champ	sauf art. 2(2)

Seuil de la grande entreprise : 250 salariés ou plus, *ou* chiffre d'affaires > 50 M€ *et* bilan > 43 M€.
HydroRégie : 380 salariés, 72 M€ de CA, 95 M€ de bilan, secteur eau potable (annexe I, point 6) → **entité essentielle**.

ANNEXE 2 · BLOC 2

Cotation des 10 domaines de l'article 21

Échelle de maturité : 0 inexistant · 1 initialisé · 2 reproductible · 3 défini · 4 maîtrisé.

ARTICLE	DOMAINE	ACTUEL	CIBLE
21(2)(a)	Analyse des risques et sécurité des SI	0	3
21(2)(b)	Gestion des incidents	1	4
21(2)(c)	Continuité, sauvegardes, gestion de crise	1	4
21(2)(d)	Sécurité de la chaîne d'approvisionnement	0	3
21(2)(e)	Acquisition, maintenance, vulnérabilités	1	3
21(2)(f)	Évaluation de l'efficacité des mesures	0	3
21(2)(g)	Cyberhygiène et formation	1	3
21(2)(h)	Cryptographie et chiffrement	1	3
21(2)(i)	RH, contrôle d'accès, gestion des actifs	1	4
21(2)(j)	Authentification multifacteur et communications	0	4
—	**Moyenne**	**0,6**	**3,3**

ANNEXE 3 · BLOC 2

Plan d'actions daté et responsabilisé

Extrait de la phase 0 « Urgences » — 95 k€ sur les 956 k€ du plan complet, et l'essentiel du risque de court terme couvert.

ID	ACTION	RESPONSABLE	ÉCHÉANCE
A-01	Créer le comité de sécurité par délibération	Direction générale	31/10/2026
A-02	Désigner le RSSI (lettre de mission signée)	Direction générale	31/10/2026
A-03	Créer le compte MonEspaceNIS2 et pré-enregistrer	DSI	31/10/2026
A-04	**Procédure de notification + 3 modèles + grille**	**RSSI**	**30/11/2026**
A-05	MFA sur l'administration et les accès distants	DSI	30/11/2026
A-06	**Sauvegarde hors ligne hebdomadaire**	**DSI**	**15/12/2026**
A-07	Versionner tous les programmes automates	Resp. exploitation	15/12/2026
A-08	Supprimer TeamViewer → VPN + MFA + bastion	DSI	31/12/2026
A-09	Annuaire de crise papier + messagerie hors domaine	RSSI	31/12/2026

39 actions au total réparties sur 4 phases, d'octobre 2026 à septembre 2028.

ANNEXE 4 · BLOC 3

Découpage en 9 zones

Chaque zone regroupe des équipements de criticité homogène. Convention d'adressage : le numéro de VLAN reprend le deuxième octet de l'adresse.

ZONE	NOM	VLAN	RÉSEAU	CRITICITÉ
Z1	Exposition Internet	100	10.100.0.0/24	Moyenne
Z2	IT bureautique	110	10.110.0.0/22	Moyenne
Z3	IT métier	120	10.120.0.0/24	Haute
Z4	Sauvegarde	130	10.130.0.0/24	Critique
Z5	**DMZ industrielle**	**200**	**10.200.0.0/24**	Critique
Z6	Supervision OT	210	10.210.0.0/24	Vitale
Z7	Contrôle OT	220	10.220.0.0/22	Vitale
Z8	Sites distants	230	10.230.0.0/22	Vitale
Z9	Administration	240	10.240.0.0/24	Critique

ANNEXE 5 · BLOC 3

Matrice de flux

Principe : **tout ce qui n'est pas explicitement autorisé est interdit**. Chaque ligne autorisée porte une justification métier et un validateur.

SOURCE	DESTINATION	PORT	JUSTIFICATION
Z6 SCADA	Z5 relais OPC UA	4840	✓ L'OT **pousse** sa donnée, jamais l'inverse
Z3 GMAO	Z5 relais OPC UA	4840	✓ Remontée des compteurs de pompes
Z6 SCADA	Z7 automates	502 · 2404	✓ Pilotage — seul flux vers le procédé
Z9 bastion	Z5 · Z6 · Z7	22 · 3389	✓ Administration tracée, session enregistrée
Toutes zones	Z9 collecteur	6514	✓ Journalisation centralisée
Z2 bureautique	**Z5 · Z6 · Z7 · Z8**	**tout**	✗ **RÈGLE CENTRALE — journalisée et alertée**
Z7 automates	Internet	tout	✗ Un automate n'a rien à faire sur Internet
Z5 DMZ	Z7 automates	tout	✗ La DMZ ne doit pas devenir un tremplin
any	any	tout	✗ DENY ALL journalisé — dernière règle

ANNEXE 6 · BLOC 4

Chronologie de crise détaillée

Scénario de rançongiciel — mardi 16 mars 2027. T0 est l'instant où l'entité a connaissance de l'incident : c'est de lui que partent les délais de l'article 23.

HEURE	ACTEUR	FAIT ET DÉCISION
04:12	**Astreinte exploitation**	**T0 — alarmes SCADA, postes inaccessibles. Ouverture de la main courante**
04:22	Responsable DSI	Chiffrement confirmé sur le serveur de fichiers et l'ERP
04:30	RSSI	Décision de couper le lien IT ↔ OT
04:45	**DSI + exploitation**	**Lien coupé en 33 min — automates en autonomie locale, l'eau continue de couler**
05:00	RSSI	Incident qualifié **important** (art. 23(3))
05:30	Cellule de crise	Réunion physique, communication hors domaine
06:15	DSI	Sauvegarde hors ligne intacte → **la rançon ne sera pas payée**
06:30	RSSI	Appel au CERT-FR pour assistance technique
07:00	DSI	Images disque réalisées *avant* toute réinstallation
14:30	**Direction générale**	**Alerte précoce transmise — T0 + 10 h 18**
15:00	Communication	Information des usagers publiée (art. 23(1))

ANNEXE 7 · BLOC 4

Délais réglementaires

Les échéances de l'article 23, et leur respect dans le scénario.

ÉCHÉANCE	DÉLAI	ARTICLE	RÉALISÉ
Alerte précoce	24 h après connaissance	23(4)(a)	✓ T0 + 10 h 18
Notification d'incident	72 h après connaissance	23(4)(b)	✓ T0 + 60 h 48
Rapport intermédiaire	sur demande du CSIRT	23(4)(c)	Non demandé
Rapport final	**1 mois après la notification**	**23(4)(d)**	**✓ J + 28 jours**
Rapport d'avancement	si incident encore en cours	23(4)(e)	Sans objet
Information des usagers	sans retard injustifié	23(1)	✓ J0 à 15 h 00
Notification CNIL	72 h — horloge distincte	art. 33 RGPD	✓ J+2
Réponse de l'autorité	24 h après l'alerte précoce	23(5)	Reçue

Le piège : le mois du rapport final court à compter de la **notification des 72 h**, et non de la découverte de l'incident.